

Документационное обеспечение информационной безопасности автоматизированных систем

ГОСТ Р 7.0.8-2013. Национальный стандарт РФ. Система стандартов по информации, библиотечному и издательскому делу. Делопроизводство и архивное дело. Термины и определения

Документ

Зафиксированная на носителе информация с реквизитами, позволяющими ее идентифицировать.

Официальный документ

Документ, созданный организацией, должностным лицом или гражданином, оформленный в установленном порядке.

Система документов

Совокупность документов, взаимосвязанных по признакам назначения, сферы деятельности и единых требований к их оформлению

Система обеспечения ИБ

совокупность организационной основы обеспечения ИБ, процессов обеспечения и управления ИБ, системы документов в области ИБ, направленных на реализацию политики ИБ.

Система документов ИБ

объединенная целевой направленностью упорядоченная совокупность документов, регламентирующих деятельность организации в области обеспечения ИБ, взаимосвязанных по функционально-целевому назначению, сфере действия, области распространения, периоду действия, а также едиными требованиями к их оформлению



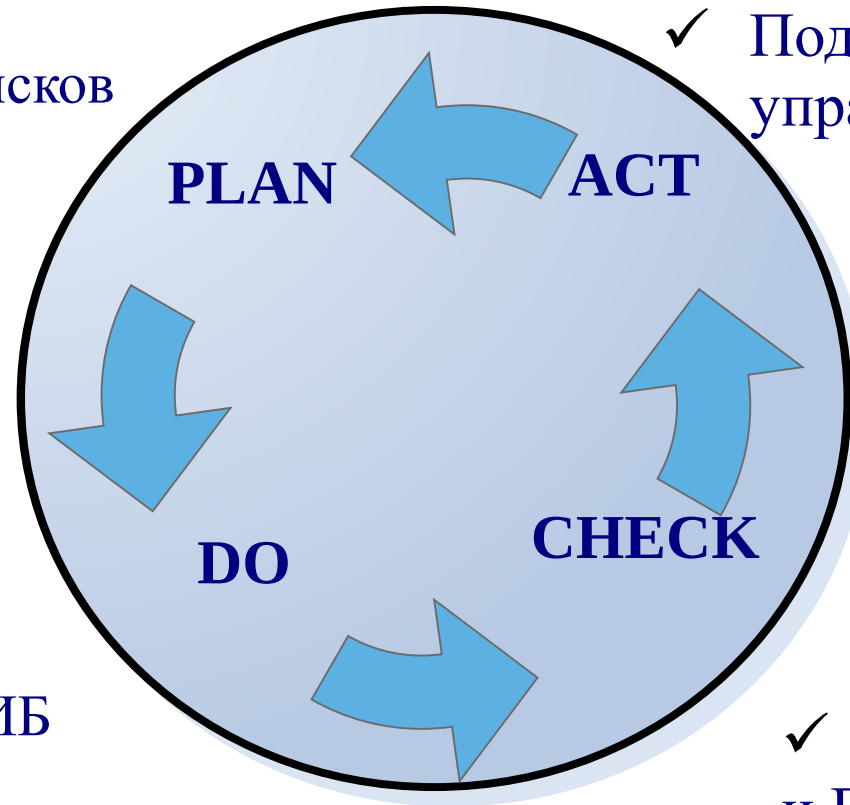
Цикл Шухарта-Деминга - модель PDCA для системы управления ИБ

Процессы планирования

- ✓ Разработка (уточнение) политики ИБ
- ✓ Классификация объектов защиты
- ✓ Оценка рисков
- ✓ Идентификация приемлемых рисков
- ✓ План по обработке рисков
- ✓ Выбор задач по реализации защитных мер
- ✓ Формирование плана обеспечения ИБ

Процессы реализации

- ✓ Реализация плана обеспечения ИБ
- ✓ Управление персоналом
- ✓ Управление инцидентами
- ✓ Обеспечение непрерывности деятельности и восстановление после инцидентов
- ✓ Анализ изменений, влияющих на СОИБ



Процессы совершенствования

- ✓ Корректирующие и превентивные действия
- ✓ Обсуждение и согласование результатов
- ✓ Подтверждение достижения задач управления

ГОСТ Р ИСО/МЭК 27001 СУИБ. Требования
ГОСТ Р ИСО/МЭК 27002

Свод норм и правил применения
мер обеспечения ИБ

СТО БР ИББС-1.0-2010 Общие положения

Процессы проверки

- ✓ Проверка соответствия СОИБ целям и Политике ИБ
- ✓ Регулярная проверка эффективности СОИБ и информирование рук-ва
- ✓ Внутренний аудит
- ✓ Анализ СОИБ руководством

Цели

- правовое регулирование отношений в области обеспечения ИБ
- повышение эффективности и согласованности процессов обеспечения и управления ИБ
- информационное обеспечение подготовки и принятия решений по обеспечению ИБ
- эффективное использование (эксплуатация) средств обеспечения и контроля эффективности ИБ
- стандартизация в области обеспечения ИБ

Задачи

- упорядочение номенклатуры документов
- формирование обоснованных и согласованных правил, требований, норм и показателей
- повышение эффективности проведения оценки соответствия требованиям по обеспечению ИБ



Принципы построения

- обоснованность порядка разработки, применения и коррекции документов
- иерархичность построения отдельных классов (видов) документов с разграничением их сферы действия и распространения
- комплексность охвата проблемы обеспечения ИБ
- непротиворечивость и взаимосогласованность документов различных уровней
- оптимальность состава (количества) документов
- обоснованность включаемых требований в документы

1. Основополагающие документы

2. Организационно-распорядительные документы

3. Документы Системы стандартизации организации

4. Информационно-справочные документы

Виды документов в области ИБ. Основопологающие документы

Концепция ИБ

Объекты защиты

Цели и задачи обеспечения ИБ

Угрозы ИБ и их источники

Основные принципы и меры обеспечения ИБ

Особенности обеспечения ИБ в сферах деятельности

Политика ИБ

Меры защиты на уровне АРМ , серверов, прикладных систем, ЛВС

Меры по обеспечению доступности

Контроль выполнения мер защиты

Основные функции службы ИБ, подразделений по защите, АДМ
по ОИБ

Основопологающие СТО

Сведения об утвержденных документах Системы стандартизации ПАО «Газпром» ежеквартально отражаются в журнале. Ссылка на журнал <http://www.gazprom.ru/about/strategy/innovation/tech-regulation/>

Все сайты «Газпрома» ▾ Контрастная версия RU EN DE Контактная информация



О «Газпроме»

Аktionерам и инвесторам

Пресс-центр

Охрана природы

Социальная ответственность

Карьера

О «Газпроме» / Стратегия / Инновационная деятельность /

Органы управления и контроля

Производство

Маркетинг

Стратегия

Разведка и добыча газа и нефти

Транспортировка и хранение газа

Переработка газа и нефти

Реализация газа

Электроэнергетика

Оптимизация затрат

Инновационная деятельность

Планирование и организация НИОКР

«Одно окно» для инновационных предложений

Техническое регулирование

Интеллектуальная собственность

Премия в области науки и техники

Дочерние компании

История

Правовая информация

Третейский суд

Техническое регулирование

С вступлением в силу Федерального закона «О техническом регулировании» в ПАО «Газпром» началась работа по совершенствованию существовавшей системы технического нормирования в Обществе.

Функции по организации и координации деятельности в области обеспечения участия специалистов Общества в работах по техническому регулированию, в том числе по разработке технических регламентов, стандартизации, сертификации и управлению качеством продукции, процессов и услуг, производимых и потребляемых ПАО «Газпром», возложены на Научно-техническое управление Департамента перспективного развития.

Для получения конкретной информации по направлениям технического регулирования предлагаем пользоваться приведенными ниже ссылками.

Технические регламенты

Специалисты структурных подразделений, дочерних обществ и организаций ПАО «Газпром» активно участвуют в разработке и обсуждении проектов технических регламентов Российской Федерации и Таможенного союза.

Перечень и текст действующих в Российской Федерации технических регламентов размещен на [официальном сайте](#) Федерального агентства по техническому регулированию и метрологии (РОССТАНДАРТ).

Уведомления о публичных обсуждениях проектов технических регламентов Российской Федерации размещены на сайте Федерального агентства по техническому регулированию и метрологии (РОССТАНДАРТ).

Уведомления о публичных обсуждениях проектов технических регламентов Таможенного союза размещены на [официальном сайте](#) Евразийской экономической комиссии.

Система стандартизации ПАО «Газпром»

Система стандартизации ПАО «Газпром» создана приказом ОАО «Газпром» (с 17 июля 2015 года — ПАО «Газпром») от 04.03.2005 № 45.

Функции Руководящего органа Системы стандартизации возложены на Департамент перспективного развития.

Работы по стандартизации осуществляются в соответствии с положениями основополагающих стандартов Системы стандартизации ПАО «Газпром»:



[СТО Газпром 1.0–2009](#)
(PDF, 118 КБ)



[СТО Газпром 1.1–2009](#)
(PDF, 2 МБ)

Виды документов в области ИБ. Организационно-распорядительные документы

Организационные документы

Определяют требования к организационной структуре СОИБ

Распорядительные документы

Приказы - решение организационных и других направлений деятельности в области ИБ

Распоряжения - решение оперативных вопросов обеспечения ИБ

Планы (графики, программы) - точный перечень, последовательность и объем работ или мероприятий по обеспечению ИБ

Иные документы, устанавливающие правила

Виды документов в области ИБ. Иные документы

Положения

Системно связанные между собой правила по вопросам, отнесенным к обеспечению ИБ

Частные политики

Требования к процессам обеспечения ИБ

Регламент

Правила организации какого-либо процесса обеспечения и управления ИБ, **порядок действий** по исполнению функций или процедур процесса

Инструкции

Правила в определенном виде деятельности по обеспечению ИБ, порядок осуществления действий (настройка средств защиты, инструкция АИБ)

Справки	Отчеты	Протоколы
Служебные записки	Паспорта защиты	
Акты классификации	Перечни сведений, относящихся к КТ	

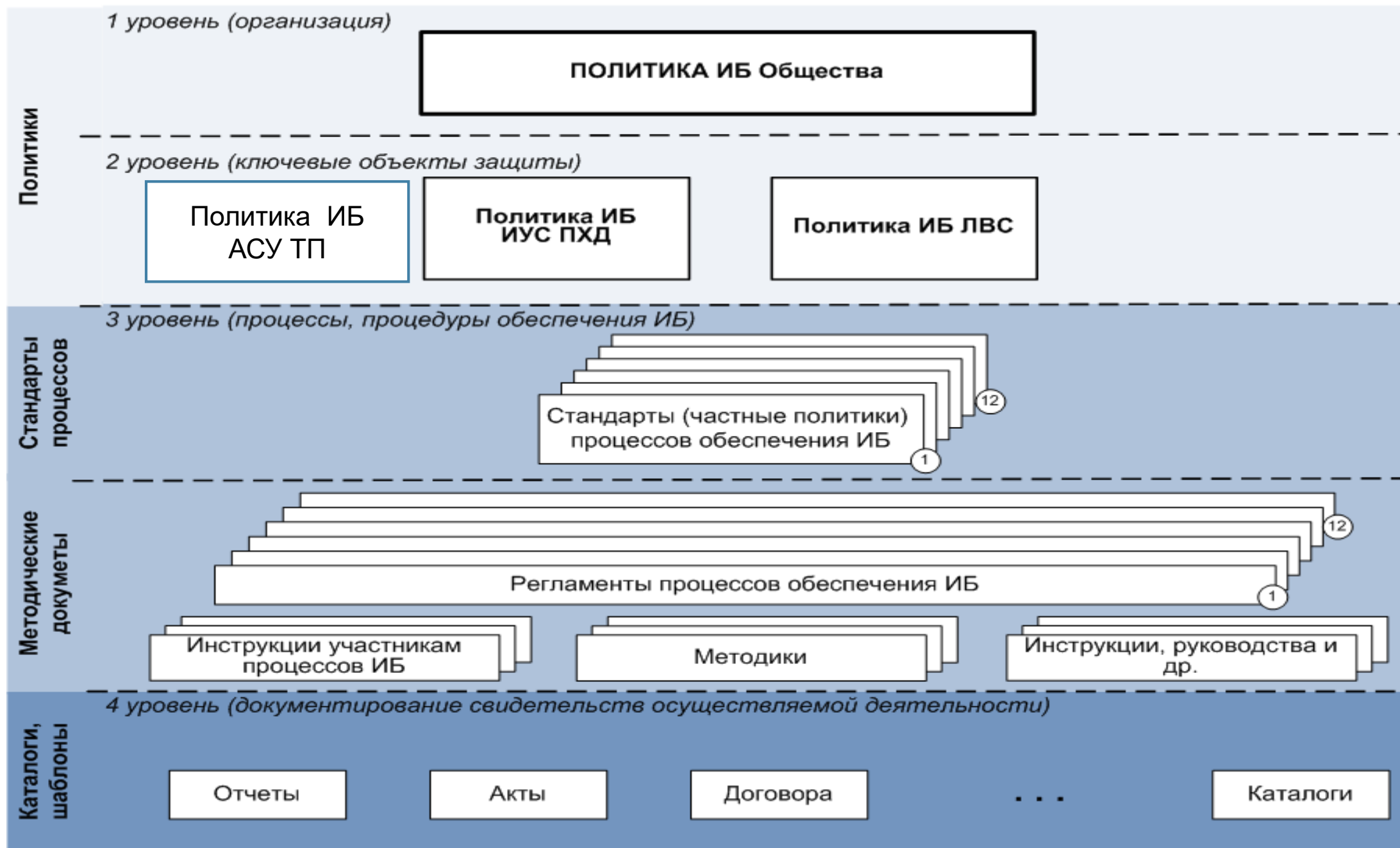
Не содержат поручений

Не устанавливают правила, нормы

Носят вспомогательный характер по отношению к ОРД

Позволяют выбрать тот или иной способ управленческого воздействия

Общая структура системы ОРД в области ИБ



Информационно-управляющая система

ИУС «ИСПД
УЗ4-УЗ1»

ИУС «без КТ
не ИСПД»

ИУС «с КТ
ИСПД»

ИУС ГИС

Центр обработки данных

ИУС «ИСПД
УЗ4-УЗ1»

ИУС «без КТ
не ИСПД»

ИУС «с КТ
ИСПД»

Автоматизированные системы управления технологическими процессами

Значимые
объекты КИИ

Не значимые
объекты КИИ

АСУ ТП

коммерческая тайна - режим конфиденциальности информации, позволяющий ее обладателю при существующих или возможных обстоятельствах увеличить доходы, избежать неоправданных расходов, сохранить положение на рынке товаров, работ, услуг или получить иную коммерческую выгоду

информация, составляющая коммерческую тайну - сведения любого характера (производственные, технические, экономические, организационные и другие), в том числе о результатах интеллектуальной деятельности в научно-технической сфере, а также сведения о способах осуществления профессиональной деятельности, которые имеют действительную или потенциальную коммерческую ценность в силу неизвестности их третьим лицам, к которым у третьих лиц нет свободного доступа на законном основании и в отношении которых обладателем таких сведений введен режим коммерческой тайны

обладатель информации, составляющей коммерческую тайну - лицо, которое владеет информацией, составляющей коммерческую тайну, на законном основании, ограничило доступ к этой информации и установило в отношении ее режим коммерческой тайны

Федеральный закон № 98-ФЗ «О коммерческой тайне»

Статья 10. Охрана конфиденциальности информации

Меры по охране конфиденциальности информации, принимаемые ее обладателем, должны включать в себя:

- 1) определение перечня информации, составляющей коммерческую тайну;
- 2) ограничение доступа к информации, составляющей коммерческую тайну, путем установления порядка обращения с этой информацией и контроля за соблюдением такого порядка;
- 3) учет лиц, получивших доступ к информации, составляющей коммерческую тайну, и (или) лиц, которым такая информация была предоставлена или передана;
- 4) регулирование отношений по использованию информации, составляющей коммерческую тайну, работниками на основании трудовых договоров и контрагентами на основании гражданско-правовых договоров;
- 5) нанесение на материальные носители, содержащие информацию, составляющую коммерческую тайну, или включение в состав реквизитов документов, содержащих такую информацию, грифа "Коммерческая тайна" с указанием обладателя такой информации (для юридических лиц - полное наименование и место нахождения, для индивидуальных предпринимателей - фамилия, имя, отчество гражданина, являющегося индивидуальным предпринимателем, и место жительства).

- Положение о режиме КТ (в т.ч. приказ об утверждении Положения).
- Перечень информации, составляющей КТ, и иной конфиденциальной информации «название организации» (в т.ч. приказ об утверждении Перечня).
- Номенклатура должностей, замещение которых предоставляет право доступа к информации, составляющей КТ
- Инструкция по конфиденциальному делопроизводству
- Инструкции о порядке передачи сведений, составляющих КТ, и других конфиденциальных сведений органам государственной власти и сторонним организациям.
- Положение о порядке подготовки и предоставления информационных материалов средствам массовой информации
- Договор о конфиденциальности или обязательства о неразглашении в Трудовом договоре (если договор о конфиденциальности не заключался)
- Соглашения о конфиденциальности (для сторонних организаций)
- Должностные инструкции работников, имеющих доступ к информации, составляющей КТ, должны содержать положения, регулирующие права работника по использованию указанной информации и устанавливающие обязанности по соблюдению режима коммерческой тайны.
- Включение в договоры с третьими лицами требований о соблюдении режима КТ
- Учет лиц, имеющих доступ к КТ или которым такая информация была передана

Перечень ОРД по КТ (примерный, справочный)

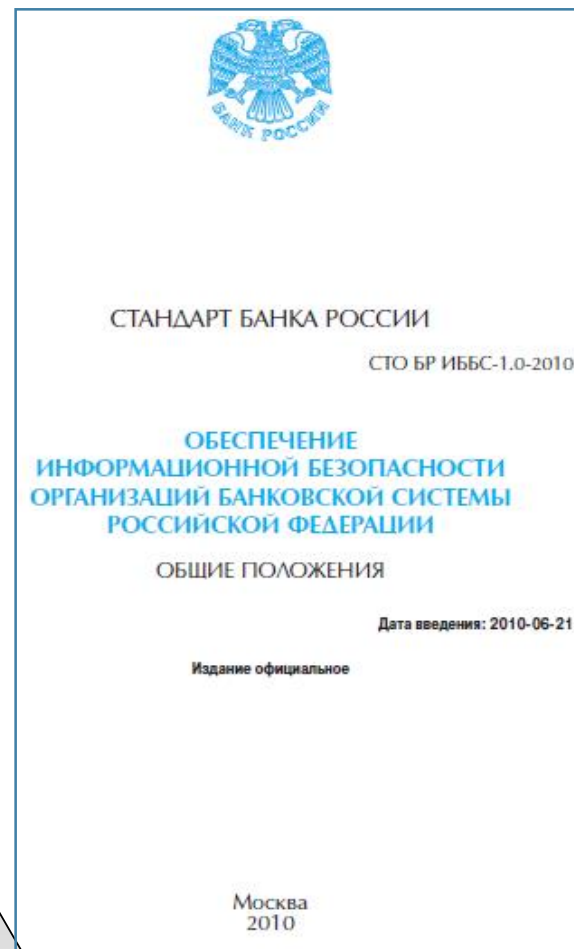
- Журнал учета проектов документов на бумажных носителях конфиденциальной информации.
- Журнал учета внешних электронных и других накопителей, используемых для хранения конфиденциальной информации.
- Журнал регистрации входящих конфиденциальных документов
- Журнал регистрации исходящих конфиденциальных документов
- Журнал учета конфиденциальных изданий
- Карточка учета конфиденциальных изданий в подразделении
- Акт приема-передачи документов (дел) с грифом «Коммерческая тайна» или «Конфиденциально»
- Карточка учета выдачи дел с грифом «Коммерческая тайна» или «Конфиденциально»
- Журнал выдачи конвертов (пакетов) с грифом «Коммерческая тайна» или «Конфиденциально»
- Список подразделений администрации, дочерних обществ и организаций для рассылки документов с грифом «Коммерческая тайна» или «Конфиденциально»
- Акт о выделении к уничтожению документов и дел с грифом «Коммерческая тайна» или «Конфиденциально», не подлежащих хранению
- Акт проверки наличия и состояния документов и дел с грифом «Коммерческая тайна» или «Конфиденциально»

Иерархия документов в области ИБ

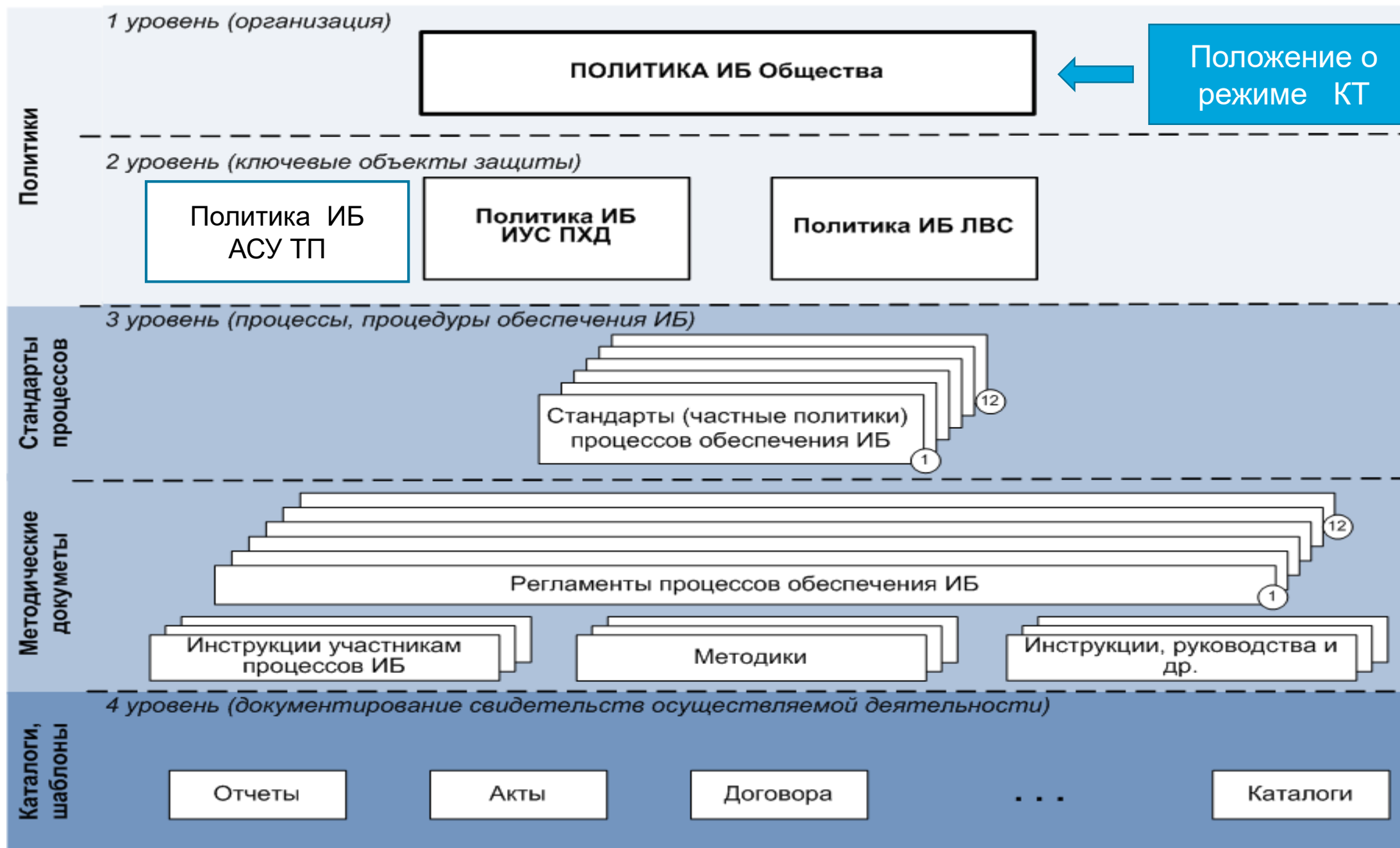
ГОСТ Р ИСО/МЭК 27001–2006



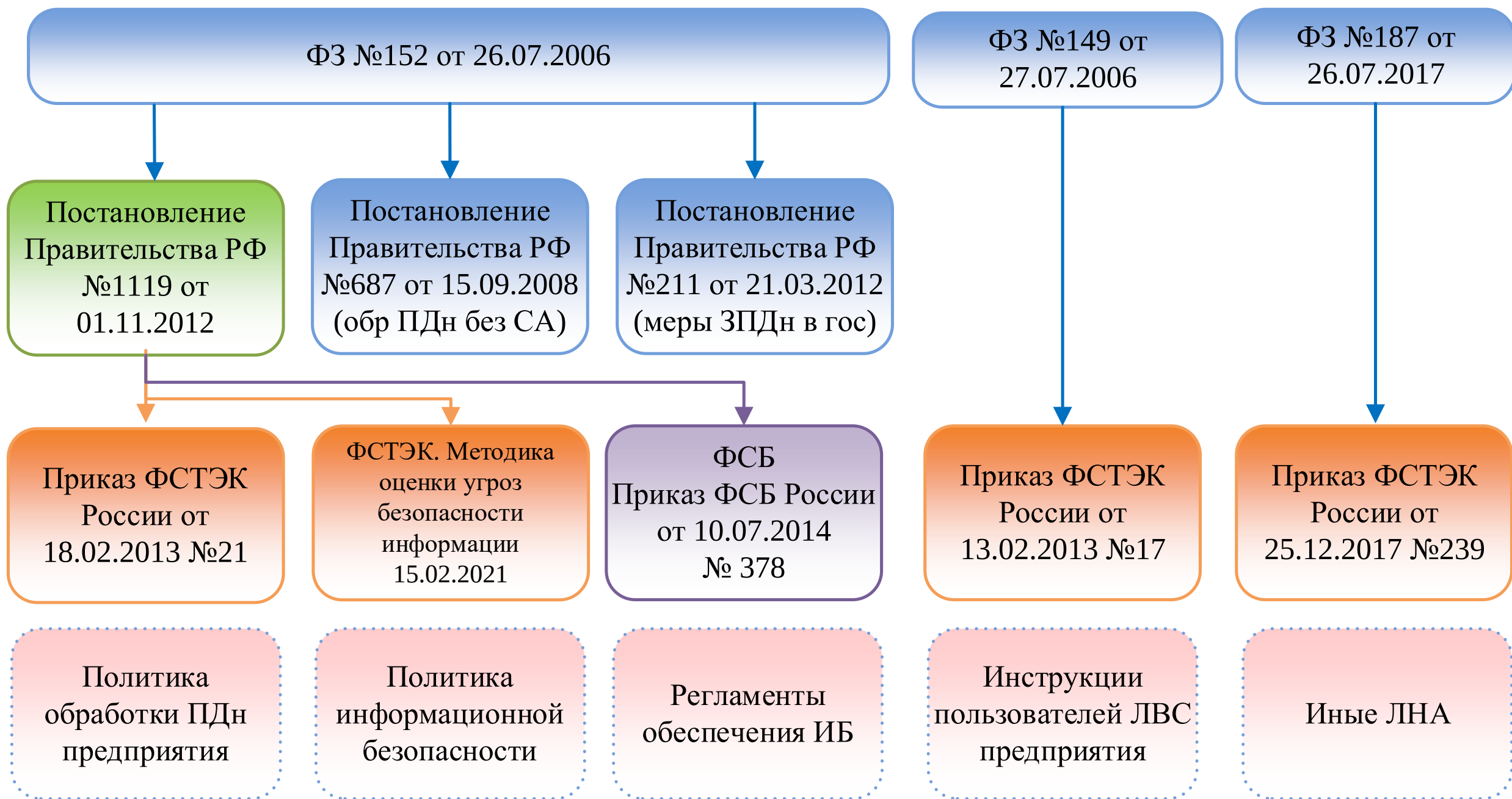
Стандарт СТО БР ИББС-1.0-2010



Общая структура системы ОРД в области ИБ



Федеральные законы и подзаконные акты в области обеспечения безопасности



Приказ ФСТЭК России № 17

ОРГАНИЗАЦИЯ ДЕЯТЕЛЬНОСТИ ПО ЗАЩИТЕ ИНФОРМАЦИИ



Разработка и утверждение политики защиты информации



Определение лиц, ответственных за защиту информации



Применение программных, программно-аппаратных средств, предназначенных для защиты информации



Разработка внутренних стандартов и регламентов по защите информации



Выделение организационных, технических и иных ресурсов, необходимых для защиты информации

РАЗРАБОТКА ПОЛИТИКИ ЗАЩИТЫ ИНФОРМАЦИИ

Область действия политики, включая перечень информации, информационных систем, компонентов информационно-телекоммуникационной инфраструктуры, подлежащих защите

- определение перечня информационных систем и защищаемой информации

Определение целей защиты информации

- исключение утечки информации ограниченного доступа и иной конфиденциальной информации;
- предотвращение несанкционированного доступа к информационным системам и содержащейся в них информации и др.

Категории лиц, участвующих в защите информации, их обязанности (функции) и полномочия (права)

- руководитель оператора, структурное подразделение, специалисты по защите информации, подрядные организации

Состав организационной системы управления деятельностью по защите информации и схему взаимодействия ее элементов

Ответственность работников за нарушение требований о защите информации

ОРГАНИЗАЦИЯ И УПРАВЛЕНИЕ ДЕЯТЕЛЬНОСТЬЮ ПО ЗАЩИТЕ ИНФОРМАЦИИ



РАЗРАБОТКА ВНУТРЕННИХ СТАНДАРТОВ И РЕГЛАМЕНТОВ ПО ЗАЩИТЕ ИНФОРМАЦИИ

Внутренние стандарты	Требования к первичной идентификации лиц, обладающих правами по доступу к информационным системам и (или) содержащейся в них информации и их использованию
	Требования к применяемым моделям доступа пользователей
	Перечень разрешенного и (или) запрещенного для использования программного обеспечения
	Требования к типовым конфигурациям и настройкам программных, программно-аппаратных средств
	Ограничения и запреты действий для пользователей при использовании и обеспечении эксплуатации ими информационных систем

требования к реализации мер по защите информации

Внутренние регламенты	Порядок создания, учета, изменения и блокирования, контроля, удаления учетных записей
	Порядок предоставления пользователям удаленного доступа к информационным системам и содержащейся в них информации
	Порядок повышения уровня знаний и информированности пользователей по вопросам защиты информации
	Порядок выявления, оценки и устранения уязвимостей информационных систем
	Порядок разработки безопасного программного обеспечения в случае его самостоятельной разработки оператором (обладателем информации)

порядок проведения мероприятий или описание реализуемых процессов